Vulnerability Scan Report

Combined findings from Nikto and OWASP ZAP

Total findings	19	**Targets**	http://127.0.0.1:4280, http://localhost:80
Scanners	Nikto, ZAP	**Findings reported by both**	3

19	5	11	3
TOTAL	MEDIUM	LOW	INFORMATIONAL

Summary of Findings

ID	Finding	Severity	Scanner(s)	URLs
1	Content Security Policy (CSP) Header Not Set	Medium	Nikto + ZAP	4
2	Apache/2.4.25 appears to be outdated (current is at least 2.4.68).	Medium	Nikto	1
3	Directory indexing found.	Medium	Nikto	2
4	Configuration information may be available remotely.	Medium	Nikto	1
5	Missing Anti-clickjacking Header	Medium	Nikto + ZAP	3
6	X-Content-Type-Options Header Missing	Low	Nikto + ZAP	6
7	Suggested security header missing: strict-transport-security.	Low	Nikto	1
8	Suggested security header missing: permissions-policy.	Low	Nikto	1
9	Suggested security header missing: referrer-policy.	Low	Nikto	1
10	Apache default file found.	Low	Nikto	1
11	Admin login page/section found.	Low	Nikto	1
12	.gitignore file found.	Low	Nikto	1
13	Cookie without SameSite Attribute	Low	ZAP	1
14	In Page Banner Information Leak	Low	ZAP	1
15	Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	ZAP	4
16	Server Leaks Version Information via "Server" HTTP Response Header Field	Low	ZAP	5
17	Authentication Request Identified	Informational	ZAP	1
18	Session Management Response Identified	Informational	ZAP	2
19	User Agent Fuzzer	Informational	ZAP	1

Detailed Findings

Medium Severity

#1 Content Security Policy (CSP) Header Not Set

MEDIUM

Severity source	ZAP	**CWE**	CWE-693
Confidence	High	**CVE**	—
Scanners	Nikto, ZAP	**Composite score**	0.10585

DESCRIPTION

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

AFFECTED (4)

Method	Affected URL
GET	http://localhost:80/
GET	http://127.0.0.1:4280/login.php
GET	http://127.0.0.1:4280/security.php
GET	http://127.0.0.1:4280/sitemap.xml

SOLUTION

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

ALSO REPORTED AS

• Suggested security header missing: content-security-policy.

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
https://www.w3.org/TR/CSP/
https://w3c.github.io/webappsec-csp/
https://web.dev/articles/csp
https://caniuse.com/#feat=contentsecuritypolicy
https://content-security-policy.com/

#2 Apache/2.4.25 appears to be outdated (current is at least 2.4.68).

MEDIUM

Severity source	Nikto keyword rules	**CWE**	—
Confidence	—	**CVE**	—
Scanners	Nikto	**Composite score**	—

DESCRIPTION

Apache/2.4.25 appears to be outdated (current is at least 2.4.68).

AFFECTED (1)

Method	Affected URL
HEAD	http://localhost:80/

#3 Directory indexing found.

MEDIUM

Severity source	Nikto keyword rules	**CWE**	CWE-548
Confidence	—	**CVE**	—
Scanners	Nikto	**Composite score**	—

DESCRIPTION

Directory indexing found.

AFFECTED (2)

Method	Affected URL
GET	http://localhost:80/config/
GET	http://localhost:80/docs/

#4 Configuration information may be available remotely.

MEDIUM

Severity source	Nikto keyword rules	**CWE**	—
Confidence	—	**CVE**	—
Scanners	Nikto	**Composite score**	—

DESCRIPTION

Configuration information may be available remotely.

AFFECTED (1)

Method	Affected URL
GET	http://localhost:80/config/

#5 Missing Anti-clickjacking Header

MEDIUM

Severity source	ZAP	**CWE**	CWE-1021
Confidence	Medium	**CVE**	—
Scanners	Nikto, ZAP	**Composite score**	5.0

DESCRIPTION

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

AFFECTED (3)

Method	Affected URL
GET	http://localhost:80/
GET	http://127.0.0.1:4280/login.php
GET	http://127.0.0.1:4280/security.php

SOLUTION

Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.
If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

ALSO REPORTED AS

• X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive.

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Low Severity

#6 X-Content-Type-Options Header Missing

LOW

Severity source	ZAP	**CWE**	CWE-693
Confidence	Medium	**CVE**	—
Scanners	Nikto, ZAP	**Composite score**	0.10585

DESCRIPTION

The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

AFFECTED (6)

Method	Affected URL
GET	http://localhost:80/
GET	http://127.0.0.1:4280/dvwa/css/login.css
GET	http://127.0.0.1:4280/dvwa/images/login_logo.png
GET	http://127.0.0.1:4280/login.php
GET	http://127.0.0.1:4280/robots.txt
GET	http://127.0.0.1:4280/security.php

SOLUTION

Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.
If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

ALSO REPORTED AS

- Suggested security header missing: x-content-type-options.
- The X-Content-Type-Options header is not set.

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)
https://owasp.org/www-community/Security_Headers

#7 Suggested security header missing: strict-transport-security.

LOW

Severity source	Nikto keyword rules	**CWE**	—
Confidence	—	**CVE**	—
Scanners	Nikto	**Composite score**	—

DESCRIPTION

Suggested security header missing: strict-transport-security.

AFFECTED (1)

Method	Affected URL
GET	http://localhost:80/

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security

#8 Suggested security header missing: permissions-policy.

LOW

Severity source	Nikto keyword rules	**CWE**	—
Confidence	—	**CVE**	—
Scanners	Nikto	**Composite score**	—

DESCRIPTION

Suggested security header missing: permissions-policy.

AFFECTED (1)

Method	Affected URL
GET	http://localhost:80/

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy

#9 Suggested security header missing: referrer-policy.

LOW

Severity source	Nikto keyword rules	**CWE**	—
Confidence	—	**CVE**	—
Scanners	Nikto	**Composite score**	—

DESCRIPTION

Suggested security header missing: referrer-policy.

AFFECTED (1)

Method	Affected URL
GET	http://localhost:80/

REFERENCES

https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy

#10 Apache default file found.

LOW

Severity source	Nikto keyword rules	**CWE**	—
Confidence	—	**CVE**	—
Scanners	Nikto	**Composite score**	—

DESCRIPTION

Apache default file found.

AFFECTED (1)

Method	Affected URL
GET	http://localhost:80/icons/README

REFERENCES

https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/

#11 Admin login page/section found.

LOW

Severity source	Nikto keyword rules	**CWE**	—
Confidence	—	**CVE**	—
Scanners	Nikto	**Composite score**	—

DESCRIPTION

Admin login page/section found.

AFFECTED (1)

Method	Affected URL
GET	http://localhost:80/login.php

#12 .gitignore file found.

LOW

Severity source	Nikto keyword rules	**CWE**	—
Confidence	—	**CVE**	—
Scanners	Nikto	**Composite score**	—

DESCRIPTION

.gitignore file found. It is possible to grasp the directory structure.

AFFECTED (1)

Method	Affected URL
GET	http://localhost:80/.gitignore

#13 Cookie without SameSite Attribute

LOW

Severity source	ZAP	**CWE**	CWE-1275
Confidence	Medium	**CVE**	—
Scanners	ZAP	**Composite score**	2.5

DESCRIPTION

A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.

AFFECTED (1)

Method	Affected URL
GET	http://127.0.0.1:4280/security.php

SOLUTION

Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.

REFERENCES

https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

#14 In Page Banner Information Leak

LOW

Severity source	ZAP	**CWE**	CWE-497
Confidence	High	**CVE**	—
Scanners	ZAP	**Composite score**	2.5

DESCRIPTION

The server returned a version banner string in the response content. Such information leaks may allow attackers to further target specific issues impacting the product and version in use.

AFFECTED (1)

Method	Affected URL
GET	http://127.0.0.1:4280/sitemap.xml

SOLUTION

Configure the server to prevent such information leaks. For example:
Under Tomcat this is done via the "server" directive and implementation of custom error pages.
Under Apache this is done via the "ServerSignature" and "ServerTokens" directives.

REFERENCES

https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/

#15 Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)

LOW

Severity source	ZAP	**CWE**	CWE-497
Confidence	Medium	**CVE**	—
Scanners	ZAP	**Composite score**	2.5

DESCRIPTION

The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.

AFFECTED (4)

Method	Affected URL
GET	http://127.0.0.1:4280/
GET	http://127.0.0.1:4280/login.php
GET	http://127.0.0.1:4280/security.php
POST	http://127.0.0.1:4280/login.php

SOLUTION

Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.

REFERENCES

https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework
https://www.troyhunt.com/shhh-dont-let-your-response-headers/

#16 Server Leaks Version Information via "Server" HTTP Response Header Field

LOW

Severity source	ZAP	**CWE**	CWE-497
Confidence	High	**CVE**	—
Scanners	ZAP	**Composite score**	2.5

DESCRIPTION

The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.

AFFECTED (5)

Method	Affected URL
GET	http://127.0.0.1:4280/
GET	http://127.0.0.1:4280/dvwa/css/login.css
GET	http://127.0.0.1:4280/dvwa/images/login_logo.png
GET	http://127.0.0.1:4280/robots.txt
POST	http://127.0.0.1:4280/login.php

SOLUTION

Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.

REFERENCES

https://httpd.apache.org/docs/current/mod/core.html#servertokens
https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)
https://www.troyhunt.com/shhh-dont-let-your-response-headers/

Informational Severity

#17 Authentication Request Identified

INFORMATIONAL

Severity source	ZAP	**CWE**	—
Confidence	High	**CVE**	—
Scanners	ZAP	**Composite score**	0.0

DESCRIPTION

The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.

AFFECTED (1)

Method	Affected URL
POST	http://127.0.0.1:4280/login.php

SOLUTION

This is an informational alert rather than a vulnerability and so there is nothing to fix.

REFERENCES

https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/

#18 Session Management Response Identified

INFORMATIONAL

Severity source	ZAP	**CWE**	—
Confidence	Medium	**CVE**	—
Scanners	ZAP	**Composite score**	0.0

DESCRIPTION

The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.

AFFECTED (2)

Method	Affected URL
GET	http://127.0.0.1:4280/security.php
POST	http://127.0.0.1:4280/login.php

SOLUTION

This is an informational alert rather than a vulnerability and so there is nothing to fix.

REFERENCES

https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/

#19 User Agent Fuzzer

INFORMATIONAL

Severity source	ZAP	**CWE**	—
Confidence	Medium	**CVE**	—
Scanners	ZAP	**Composite score**	0.0

DESCRIPTION

Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.

AFFECTED (1)

Method	Affected URL
GET	http://127.0.0.1:4280/security.php

REFERENCES

https://owasp.org/wstg